

Segurança em Sistemas Operacionais e Redes de Computadores I

ISG012-05 - Firewalls de Host: Defesa do Endpoint em Sistemas Operacionais

Objetivo

- Compreender a arquitetura e funcionamento dos firewalls de host em ambientes Windows e Linux, identificando os diferentes perfis de segurança, regras de tráfego inbound e outbound, mecanismos de logging, comparando as abordagens de segurança entre plataformas proprietárias e livres.

Arquitetura de Firewalls de Host

- O firewall de host constitui a última linha de defesa na arquitetura de segurança em camadas, operando diretamente sobre o sistema operacional para filtrar tráfego de rede na camada de aplicação e transporte. Diferente dos firewalls de perímetro, protege endpoints individuais através da inspeção de pacotes que entram (inbound) e saem (outbound) da máquina, aplicando políticas baseadas em endereços IP, portas, protocolos e aplicações específicas, integrando-se ao kernel ou subsistema de rede do sistema operacional.

Arquitetura de Firewalls de Host

- Definição: Software de filtragem de tráfego instalado no endpoint
- Posicionamento: Camada de host no modelo Defense in Depth
- Escopo: Proteção individual vs. firewalls de rede (proteção de segmento)
- Funcionalidades: Stateful inspection, filtragem por aplicação, logging local
- Integração: Kernel-level (Linux) ou serviço do sistema (Windows)

Arquitetura Defense in Depth: Firewall de Host

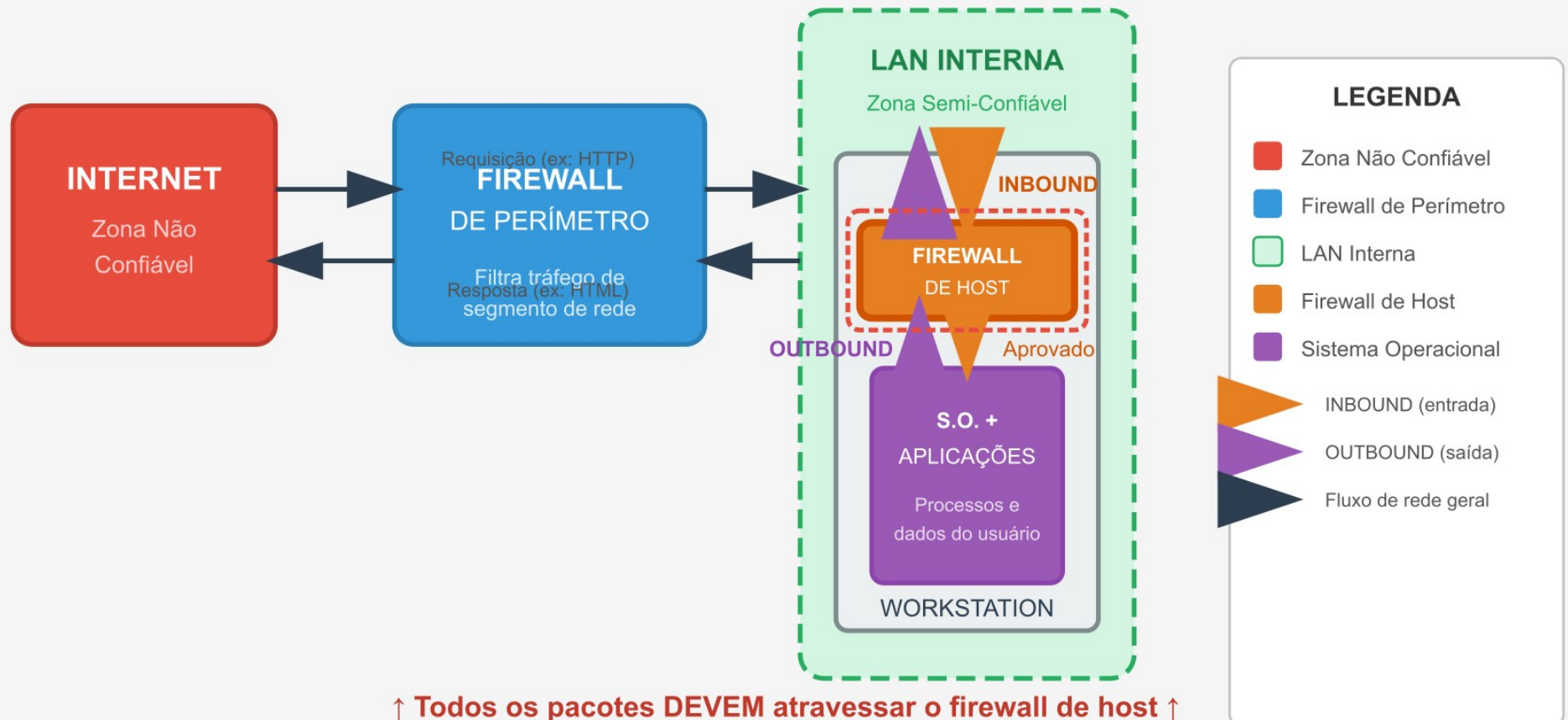


Figura 1: Firewall de Host como camada obrigatória de inspeção entre a rede e o sistema operacional

Inspeção Stateful vs Stateless

- A inspeção stateful (com estado) representa a capacidade do firewall de manter o contexto das conexões de rede em uma tabela de estados, diferenciando pacotes que iniciam novas conexões daqueles que respondem a comunicações já estabelecidas;
- Diferentemente da abordagem stateless (sem estado), que analisa cada pacote isoladamente baseado apenas em headers, o stateful inspection rastreia o ciclo completo da conexão TCP (SYN, SYN-ACK, ACK) e associações UDP, permitindo regras mais seguras que bloqueiam tráfego não solicitado enquanto permitem respostas válidas a requisições internas, reduzindo a superfície de ataque sem comprometer a funcionalidade.

Inspeção Stateful vs Stateless

- Stateful: Mantém tabela de conexões ativas (conntrack); permite established/related
- Stateless: Análise packet-by-packet; regras estáticas baseadas em portas/IP
- Vantagem Stateful: Bloqueia scans furtivos e pacotes fora de sequência TCP
- Implementação Windows: Windows Firewall é stateful por padrão (diferenciação de conexões)
- Implementação Linux: Netfilter com módulo conntrack; nftables usa ct state

Inspeção Stateful: Tabela de Rastreamento de Conexões (conntrack)

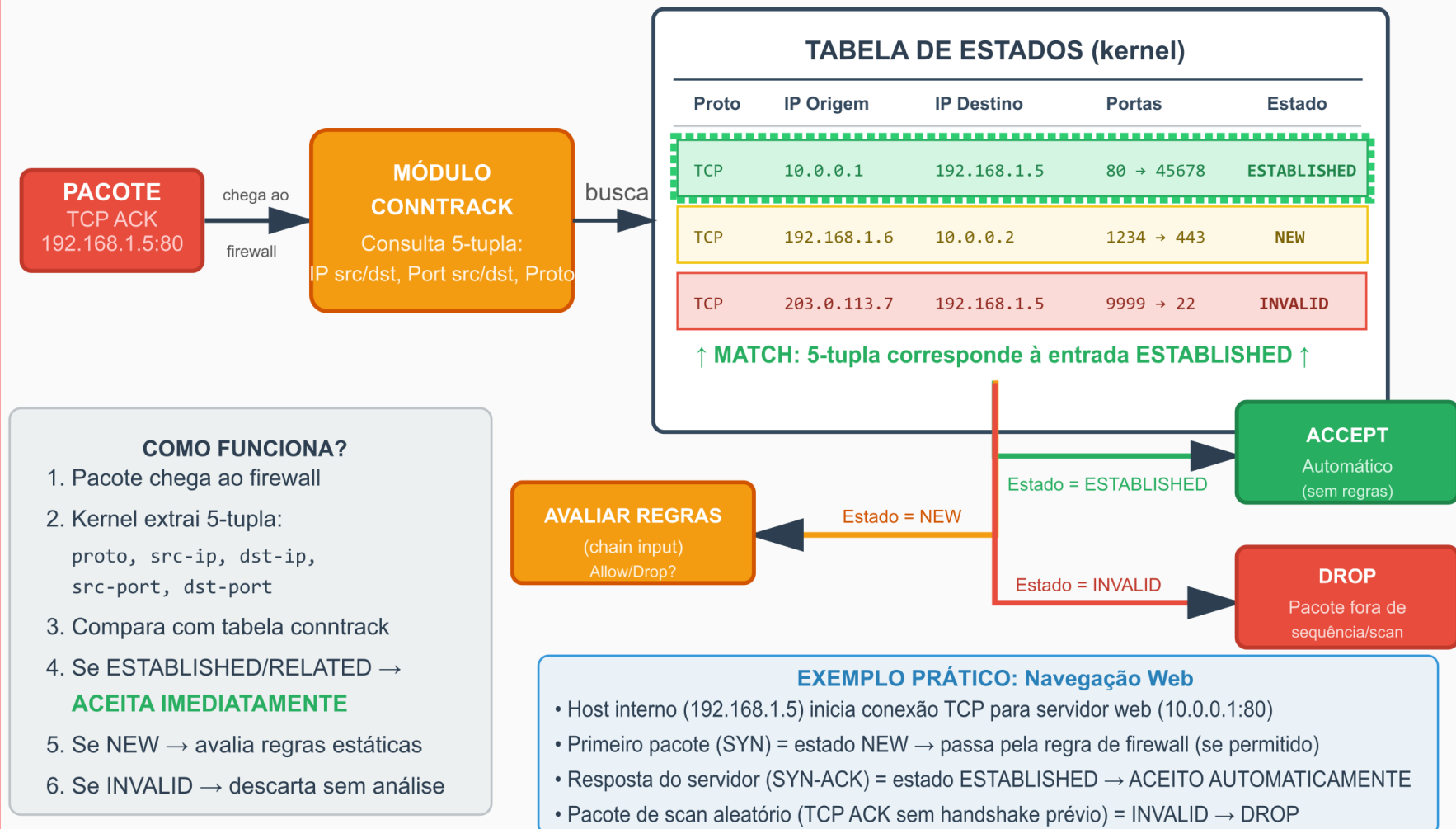


Figura 2: Fluxo de decisão stateful baseado no estado da conexão na tabela conntrack

Windows Firewall: Perfis de Rede

- O Windows Firewall implementa três perfis de segurança adaptativos que se ativam automaticamente conforme a localização da conexão de rede detectada;
- O perfil Domain aplica-se quando o computador se conecta a uma rede corporativa com controlador de domínio autenticado, oferecendo políticas mais permissivas para serviços empresariais;
- O perfil Private destina-se a redes domésticas ou de pequenos escritórios confiáveis, enquanto o perfil Public protege computadores em redes não confiáveis como Wi-Fi públicos, aplicando as restrições mais rigorosas.

Windows Firewall: Perfis de Rede

- Domain Profile: Ativo quando autenticado no AD; políticas corporativas aplicadas; discovery habilitado
- Private Profile: Redes confiáveis identificadas pelo usuário; compartilhamento de arquivos permitido
- Public Profile: Redes não identificadas; descoberta de rede desativada; bloqueio estrito de entrada
- Características: Perfis mutualmente exclusivos por interface de rede; adaptação automática
- Configuração: Gerenciável via GUI (wf.msc), GPO ou PowerShell (Set-NetFirewallProfile)

Windows Firewall: Perfis de Rede

- Domain Profile: Ativo quando autenticado no AD; políticas corporativas aplicadas; discovery habilitado
- Private Profile: Redes confiáveis identificadas pelo usuário; compartilhamento de arquivos permitido
- Public Profile: Redes não identificadas; descoberta de rede desativada; bloqueio estrito de entrada
- Características: Perfis mutualmente exclusivos por interface de rede; adaptação automática
- Configuração: Gerenciável via GUI (wf.msc), GPO ou PowerShell (Set-NetFirewallProfile)

Windows Firewall: Perfis de Rede



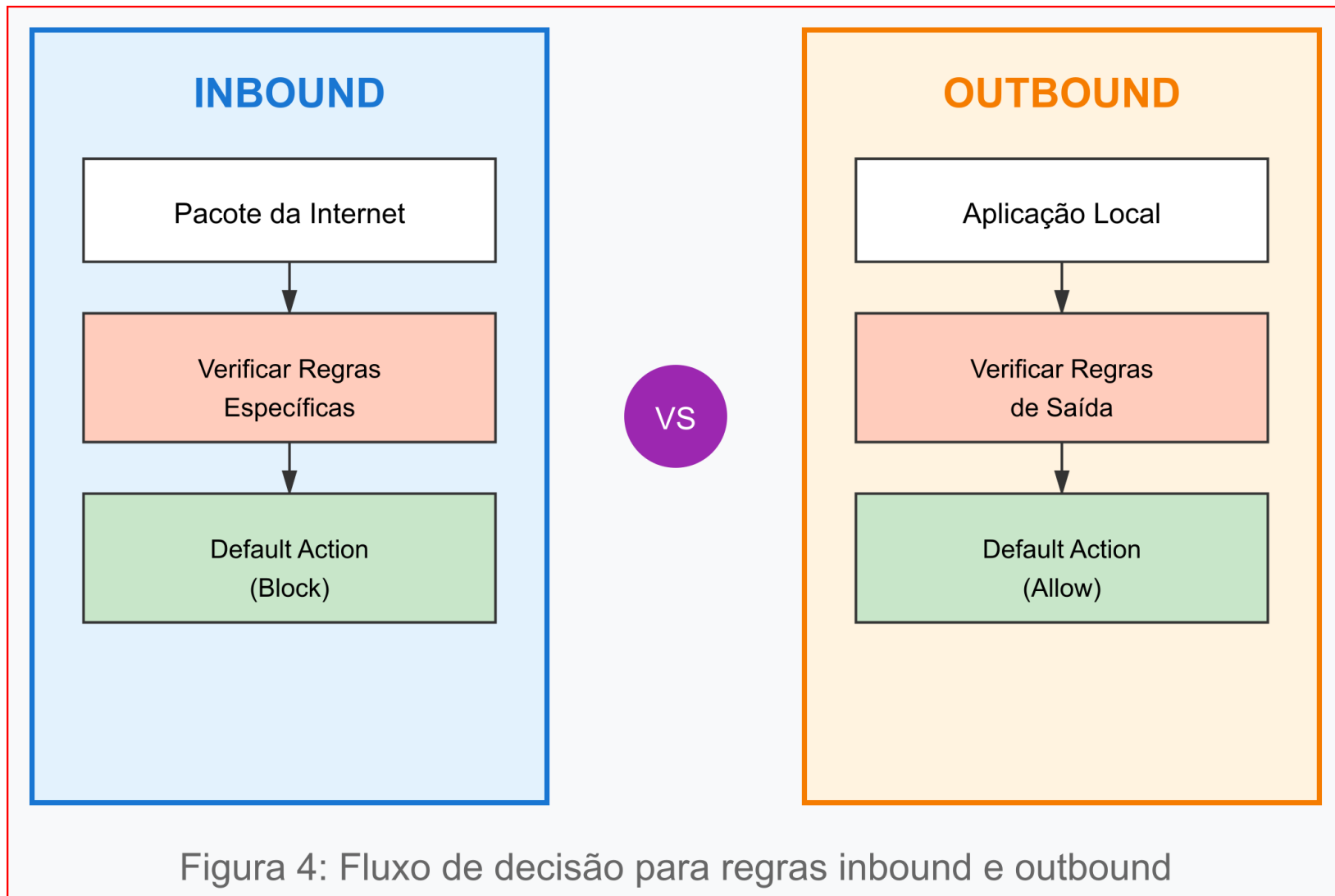
Regras Inbound e Outbound

- As regras de firewall definem o comportamento do tráfego baseado na direção da comunicação;
- Regras inbound controlam conexões iniciadas externamente que tentam alcançar o host, protegendo contra acessos não solicitados a serviços locais;
- Regras outbound gerenciam conexões iniciadas pelo host para destinos externos, essenciais para impedir que malware se comunique com servidores de comando e controle (C2) ou exfiltre dados;
- Ambas permitem especificar portas TCP/UDP, protocolos ICMP, caminhos de executáveis e perfis de rede aplicáveis.

Regras Inbound e Outbound

- Inbound Rules: Bloqueiam/permitem tráfego externo entrante; críticas para servidores locais; proteção contra scans
- Outbound Rules: Controlam tráfego de saída; importante para prevenir exfiltração de dados e comunicação C2
- Default Action: Geralmente allow outbound, block inbound (postura padrão Windows); Linux frequentemente drop all
- Escopo: Aplicáveis por perfil (Domain/Private/Public) ou interface específica
- Ações: Allow (permitir), Block (bloquear), Allow if secure (refere-se a uma ação avançada do Windows Firewall que condiciona a permissão de tráfego à autenticação e criptografia via protocolo IPsec (Internet Protocol Security))

Regras Inbound e Outbound



Logging e Monitoramento

- O registro de eventos do firewall fornece auditoria essencial para análise forense e detecção de tentativas de intrusão;
- O Windows Firewall gera logs em arquivo texto localizado em %SystemRoot%\System32\LogFiles\Firewall\pfirewall.log, registrando conexões dropadas e bem-sucedidas conforme configuração;
- A integração com o Event Viewer permite correlacionar eventos de segurança (IDs 5150-5159) com outras atividades do sistema, possibilitando a identificação de padrões de scanning, tentativas de conexão em portas fechadas e violações de políticas de segurança estabelecidas.

Logging e Monitoramento

- Localização do log: C:\Windows\System32\LogFiles\Firewall\pfirewall.log⁽¹⁾
- Event IDs relevantes: 5150 (regra bloqueada), 5156 (conexão permitida), 5157 (conexão bloqueada)
- Configuração: Tamanho máximo do log, dropped packets only vs. successful connections
- Análise: Visualização via Event Viewer ou PowerShell (Get-WinEvent, Get-Content)
- Integração: Encaminhamento via syslog para SIEM corporativo; análise de padrões de ataque

(1)

Versão do Windows	Comportamento Padrão
Windows XP/Vista/7/8	`pfirewall.log` existia e era populado por padrão
Windows 10/11/Server 2016+	Logging **desativado por padrão**; apenas Event Viewer (IDs 515x)
Windows Server 2022	Logging desativado; requer configuração manual ou GPO

Formato de Log do Windows Firewall (pfirewall.log)

pfirewall.log - Bloco de Notas

#Version: 1.5

#Software: Microsoft Windows Firewall

#Time: [UTC]

date time action protocol src-ip dst-ip src-port dst-port size tcpflags tcpsyn tcpack tcpwin icmp type icmpcode info path

2024-01-15 14:23:45 DROP TCP 192.168.1.100 10.0.0.5 45678 80 - - - - - RECEIVE

2024-01-15 14:23:48 DROP TCP 192.168.1.100 10.0.0.5 45679 22 - - - - - RECEIVE

2024-01-15 14:24:12 ALLOW UDP 10.0.0.5 8.8.8.8 53 53 - - - - - SEND

LEGENDA DOS CAMPOS

date/time → Data e hora UTC do evento

src-port / dst-port → Portas origem/destino

action → Decisão: DROP (bloqueio) ou ALLOW

size (permissão) → Tamanho do pacote (bytes)

protocol → TCP, UDP, ICMP (camada 4)

tcpflags... → Flags TCP (SYN, ACK, etc.)

src-ip / dst-ip → IP origem e destino

path → Direção: RECEIVE (entra) ou SEND (sai)

Metadados do arquivo (cabeçalho)

Nomes dos campos (estrutura)

Dados do tráfego capturado

△ Análise: Duas tentativas DROP seguidas (portas 80 e 22) = possível scan de portas

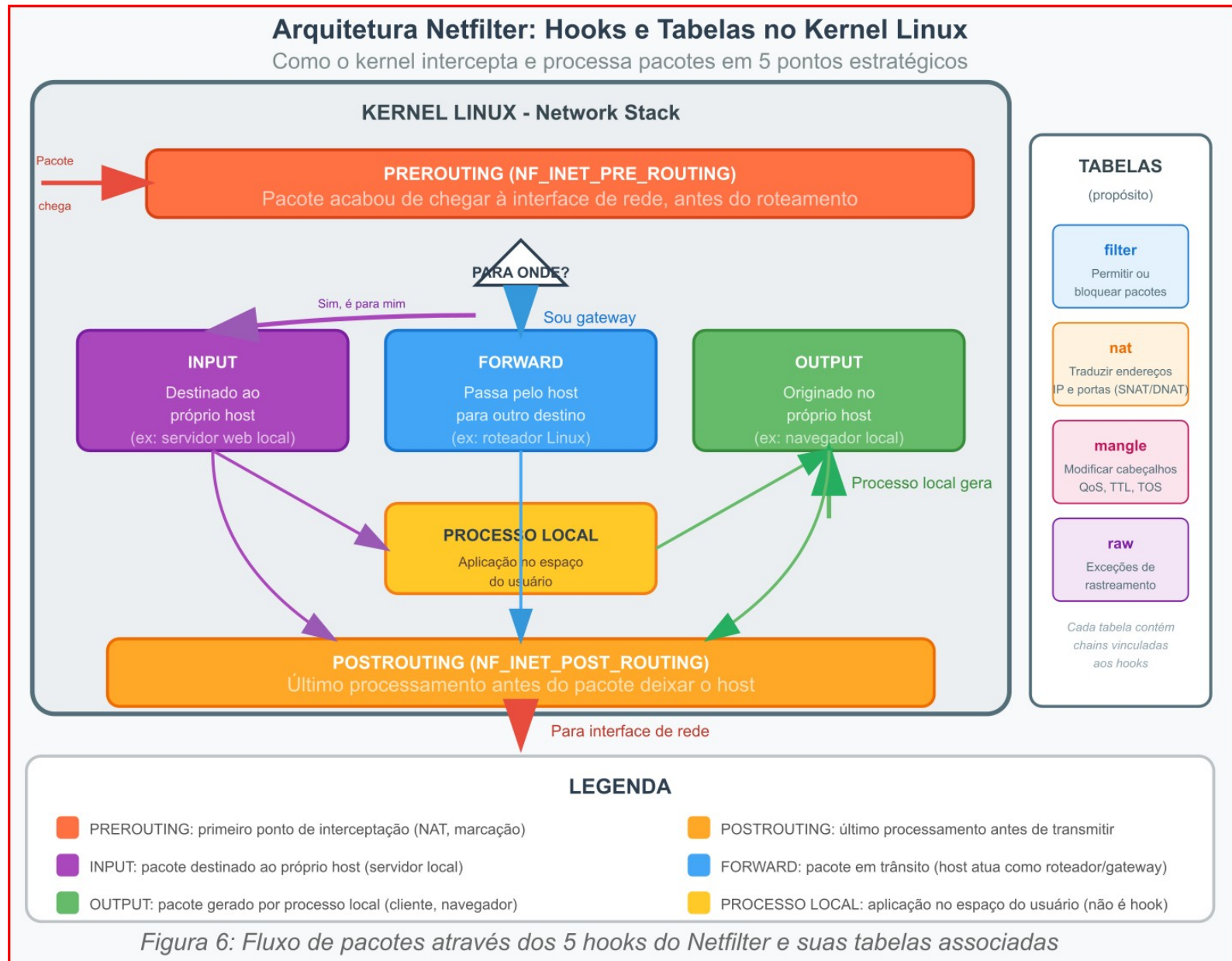
Figura 5: Formato de log pfirewall.log com decodificação dos campos e análise forense

Netfilter: Arquitetura Linux

- O Netfilter representa o framework de filtragem de pacotes integrado ao kernel Linux desde a versão 2.4, constituindo a base para ferramentas como iptables, ip6tables e nftables;
- Sua arquitetura implementa hooks em pontos estratégicos da pilha de rede (PREROUTING, INPUT, FORWARD, OUTPUT, POSTROUTING), permitindo interceptar e manipular pacotes através de tabelas especializadas (filter, nat, mangle, raw);
- A transição para nftables oferece sintaxe unificada, melhor desempenho e atomicidade na atualização de regras, substituindo as cadeias separadas do legado iptables.

Netfilter: Arquitetura Linux

- Framework: Subsistema do kernel Linux para manipulação de pacotes; hook-based architecture;
- Tabelas: filter (permitir/bloquear), nat (tradução de endereços), mangle (modificação QoS), raw (exceções de tracking);
- Chains: INPUT (para o host), OUTPUT (do host), FORWARD (pass-through), PREROUTING/POSTROUTING (NAT);
- Nftables: Sucessor moderno do iptables; sintaxe consolidada IPv4/IPv6; performance superior via bytecode;
- Estado: Stateful - inspeção através do “connection tracking” (conntrack) integrado.



Nftables vs Iptables

- A evolução do iptables para nftables representa uma modernização significativa no gerenciamento de firewalls Linux;
- Enquanto o iptables mantinha cadeias separadas para IPv4 e IPv6, exigindo duplicação de regras, o nftables unifica a configuração em uma única tabela inet;
- A nova arquitetura utiliza uma máquina virtual de bytecode no kernel, oferecendo melhor performance e menor consumo de memória;
- A atomicidade das operações permite atualizar conjuntos inteiros de regras instantaneamente, eliminando estados transitórios vulneráveis que ocorriam nas atualizações sequenciais do iptables.

Nftables vs Iptables

- Unificação: Tabela inet cobre IPv4 e IPv6 simultaneamente; elimina duplicação de regras
- Sintaxe: Nftables usa sintaxe declarativa mais legível; iptables usa múltiplos utilitários (iptables, ip6tables, ebtables)
- Sets e Maps: Estruturas de dados eficientes para listas de IPs/portas sem criar regras individuais
- Atomicidade: Aplicação instantânea de todas as regras via arquivo de configuração único
- Debugging: Melhor feedback de erros e tracing integrado (nft trace)

Integração Windows com AD

- GPO Deployment: Distribuição automática de regras via Group Policy; aplicação em massa
- Autenticação de Perfil: Validação via DC e Kerberos para ativação do Domain Profile
- WMI Filters: Aplicação condicional de regras baseada em atributos do sistema
- SecPol: Security Policy snap-in para configurações hardcoded em máquinas domain-joined
- Monitoramento Centralizado: Event logs encaminhados para coletores via Subscription

Comparação Windows vs Linux

- As soluções de firewall de host apresentam filosofias distintas: o Windows Firewall oferece integração nativa com o ecossistema Microsoft, gerenciamento simplificado através de interfaces gráficas e PowerShell, com foco em usabilidade para administradores de infraestrutura heterogênea;
- Em contraste, as soluções Linux baseadas em netfilter proporcionam granularidade extrema através de linha de comando, scriptabilidade avançada com bash, e modularidade para cenários especializados de segurança, embora exijam maior curva de aprendizado técnico e conhecimento profundo de protocolos de rede.

Melhores Práticas de Hardening

- A configuração segura de firewalls de host requer aplicação do princípio do menor privilégio, iniciando com políticas default-deny para tráfego inbound e monitoramento cuidadoso de outbound;
- Regras devem ser específicas quanto a portas e endereços, evitando ranges amplos, e devem incluir logging para auditoria. A separação de perfis (especialmente Public vs Private) deve ser rigorosamente mantida, e regras obsoletas removidas periodicamente;
- Em ambientes corporativos, automação via PowerShell ou ansible garante consistência, enquanto testes regulares de penetração validam a eficácia das políticas implementadas.

Melhores Práticas de Hardening

- **Default Deny:** Bloquear todo tráfego inbound não explicitamente necessário; princípio do menor privilégio;
- **Regras Específicas:** Evitar wildcards (*); especificar portas, protocolos e origens exatas;
- **Auditoria:** Manter logging habilitado para conexões dropadas; revisão periódica de logs;
- **Higiene:** Remover regras temporárias e desativadas; documentar propósito de cada regra;
- **Automação:** Versionar configurações (Git); usar IaC (Infrastructure as Code) para consistência.

Comparação Windows vs Linux

- Interface: Windows (GUI + PowerShell orientado a objetos) vs Linux (CLI/bash declarativo)
- Política padrão: Windows (permissivo outbound) vs Linux (frequentemente restrictivo drop-all)⁽¹⁾
- Integração: Windows (Active Directory, GPOs nativos) vs Linux (scripts init, systemd, ferramentas de config management)
- Granularidade: Windows (aplicação/porta/perfil) vs Linux (pacote/protocolo/estado/interface)⁽²⁾
- Custo e Licenciamento: Windows (componente do SO licenciado) vs Linux (código aberto, ferramentas 100% livres)

(1)

Postura	Significado	Efeito Prático
Permissivo outbound	Tudo que sai é permitido, exceto o explicitamente bloqueado	O host confia em si mesmo; aplicações comunicam livremente
Restrictivo drop-all	Tudo é bloqueado, exceto o explicitamente permitido	O host não confia em ninguém, nem em si mesmo; cada pacote precisa de autorização

(2) A granularidade refere-se ao nível de detalhe com que o firewall pode inspecionar e filtrar o tráfego. Quanto mais granular, mais preciso é o controle — mas também maior a complexidade de configuração. O Windows Firewall pensa em "quem está tentando fazer o quê, de onde". Sua unidade básica de controle é o contexto da aplicação e do usuário. O Linux (via Netfilter/nftables) pensa em "o que este pacote específico contém e como se comporta". Sua unidade básica é o pacote individual e seus atributos técnicos.